

MÉMOIRE DE FIN D'ÉTUDES - ENSPY
AUDIT DE SÉCURITÉ APPLICATIVE FUSIONNÉ
Méthode MUSA : Cas GIDOCEP / SOLTEC

GUIDE D'ENTRETIEN FUSIONNÉ

Mission MUSA-GIDOCEP-2026-SOLTEC

Référence mission	MUSA-GIDOCEP-2026-SOLTEC
Type de document	Guide d'entretien fusionné
Date d'établissement	
Version	V1.0 Draft soumis à validation
Nb de questions	41 questions fusionnées dérivées des 21 assertions du référentiel MUSA
Nb de domaines	5 domaines fusionnés : A. Authentification & Accès B. Journalisation & Traçabilité C. Sécurité des données D. Continuité & Sauvegarde E. Gouvernance & Organisation
Classification	CONFIDENTIEL, Usage exclusif mission de fin d'études

Fondement méthodologique et consignes d'utilisation

Ce guide est dérivé directement des 21 assertions fusionnées du référentiel MUSA (technique + organisationnel réunis dans une seule question par sous-volet). Chaque question teste la réponse de l'AUDITÉ jamais la performance de l'auditeur. La réponse obtenue est enregistrée dans l'Outil MUSA sous la forme OK / KO / NSP pour le sous-volet interrogé (technique ou organisationnel), puis fusionnée automatiquement en O (conforme) / N (non conforme) / PAS (pas assez d'éléments).

Règle PAS : une réponse PAS est un signal diagnostique de premier rang, non un aveu d'échec de l'auditeur. Elle déclenche un approfondissement obligatoire (entropie de Shannon $H \geq 1,0$ sur le domaine concerné).

Consignes d'utilisation

- Poser chaque question dans l'ordre prévu ; ne pas suggérer la réponse ni orienter l'interlocuteur.
- Relancer systématiquement par la relance-preuve indiquée pour chaque réponse positive de l'audité.
- Toute réponse de l'audité doit être étayée par un document ou une observation physique ; une réponse non documentée est codée NSP (KO/PAS).
- Enregistrer immédiatement la réponse de l'audité dans l'Outil MUSA (PT correspondant) ; ne pas attendre la fin de la journée.
- Les questions de priorité H sont non négociables, même dans un entretien court (contexte PME, disponibilité limitée).
- Pour chaque assertion, le sous-volet 'a' teste le critère technique, le sous-volet 'b' teste le critère organisationnel — les deux réponses de l'audité sont nécessaires pour calculer la réponse fusionnée O/N/PAS.

H = Priorité Haute (indispensable) | M = Priorité Moyenne (si le temps le permet) | F = Priorité Faible (vérifiable sur document seul)

Interlocuteurs concernés : Matrice de couverture (échelle PME)

Contrairement à un audit SI multi-logiciel qui mobilise 8-9 interlocuteurs, la mission fusionnée MUSA sur GIDOCEP cible un nombre réduit d'interlocuteurs, cohérent avec la taille de SOLTEC.

Interlocuteur	A	B	C	D	E	Durée estimée
Responsable technique / développeur GIDOCEP	✓	✓	✓	✓	✓	60 min
Direction SOLTEC / encadreur professionnel	—	—	—	—	✓	30 min
Administrateur système ou hébergeur (si distinct)	✓	✓	✓	✓	—	30 min
Utilisateur clé de GIDOCEP (agent d'un établissement public client)	✓	—	—	—	—	20 min

Questions d'entretien par domaine fusionné

Réf.	Question fusionnée (technique + organisationnel)	Prio.	Relance / preuve à demander
DOMAINE A : Authentification & Contrôle d'accès (assertions A1–A3)			
A1a	Comment les mots de passe des comptes GIDOCEP sont-ils protégés techniquement (hachage, MFA pour les comptes sensibles) ?	H	« Pouvez-vous me montrer la configuration ou un extrait de code ? »
A1b	Existe-t-il une politique de mots de passe formalisée et une procédure MFA pour les comptes à privilèges ?	H	« Puis-je voir le document de politique signé ? »
A2a	Comment les droits d'accès sont-ils limités aux fonctions strictement nécessaires de chaque profil GIDOCEP ?	H	« Montrez-moi l'extraction des droits par profil. »
A2b	Une revue périodique des droits d'accès est-elle organisée et documentée ?	M	« Avez-vous un rapport de la dernière revue ? »
A3a	Les comptes inactifs depuis 90 jours sont-ils désactivés techniquement ?	H	« Pouvez-vous extraire la liste des comptes inactifs ? »
A3b	Une procédure formalisée de revue périodique des accès existe-t-elle ?	M	« Puis-je voir la procédure signée ? »
DOMAINE B : Journalisation & Traçabilité (assertions B1–B2)			
B1a	Un journal applicatif actif enregistre-t-il création, modification et suppression avec horodatage sur GIDOCEP ?	H	« Montrez-moi un extrait de logs. »
B1b	Ces logs sont-ils réellement exploités dans une procédure de gestion des incidents ?	H	« Puis-je voir la procédure et un exemple d'usage récent ? »
B2a	Un dispositif de détection d'intrusion (IDS/IPS) est-il actif sur l'environnement GIDOCEP ?	M	« Montrez-moi la configuration ou le journal d'alertes. »
B2b	Une procédure de réponse aux alertes de sécurité est-elle formalisée ?	M	« Puis-je voir la procédure de réponse aux incidents ? »
DOMAINE C : Sécurité des données (assertions C1–C4)			
C1a	Les données en transit (TLS) et au repos (chiffrement) sont-elles protégées pour GIDOCEP ?	H	« Puis-je voir un rapport de scan TLS ou la configuration de chiffrement ? »
C1b	Une politique de classification et de chiffrement des données est-elle formalisée ?	H	« Puis-je voir le document de politique ? »
C2a	GIDOCEP rejette-t-il techniquement les données incomplètes ou hors plage à la saisie ?	M	« Montrez-moi un test ou une spécification de validation. »
C2b	Ces règles de validation sont-elles documentées comme règles de gestion métier formalisées ?	F	« Puis-je voir la documentation validée ? »
C3a	Les rapports et documents sensibles produits par GIDOCEP sont-ils accessibles uniquement aux personnes habilitées ?	H	« Montrez-moi le paramétrage des droits sur les états. »
C3b	Une procédure de diffusion sécurisée de ces états est-elle formalisée ?	M	« Puis-je voir la liste des destinataires habilités ? »
C4a	L'identité des applications sources est-elle vérifiée techniquement avant acceptation d'un flux vers/depuis GIDOCEP ?	M	« Montrez-moi la configuration d'authentification inter-applicative. »
C4b	Une procédure de gestion des interfaces est-elle formalisée ?	F	« Puis-je voir la politique de gestion des interfaces ? »
DOMAINE D : Continuité & Sauvegarde (assertions D1–D2)			

D1a	Les sauvegardes de GIDOCEP sont-elles automatisées, stockées hors site et testées techniquement ?	H	« Puis-je voir le journal de sauvegarde et un rapport de test de restauration ? »
D1b	Un Plan de Reprise d'Activité formalisé définit-il un RTO/RPO pour GIDOCEP ?	H	« Puis-je voir le PRA signé ? »
D2a	Une architecture de haute disponibilité (cluster, load-balancing) est-elle en place pour GIDOCEP ?	M	« Montrez-moi le schéma d'architecture. »
D2b	Un Plan de Continuité d'Activité est-il formalisé pour l'application ?	M	« Puis-je voir le PCA validé ? »
DOMAINE E : Gouvernance & Organisation applicative (assertions E1–E4)			
E1	Un propriétaire applicatif est-il désigné et documenté pour GIDOCEP ?	H	« Puis-je voir la note de désignation ou la fiche de poste ? »
E2a	Les patches de sécurité de l'OS et de l'application GIDOCEP sont-ils appliqués régulièrement ?	H	« Montrez-moi le rapport de gestion des patches. »
E2b	Une politique de gestion des correctifs est-elle formalisée et approuvée ?	M	« Puis-je voir la politique signée ? »
E3a	GIDOCEP utilise-t-il des requêtes paramétrées ou un ORM pour se protéger des injections SQL ?	H	« Puis-je voir un extrait de code ou un rapport de test de pénétration ? »
E3b	Un guide de codage sécurisé est-il formalisé et appliqué par l'équipe de développement ?	M	« Puis-je voir le guide approuvé ? »
E4a	Les équipements liés à GIDOCEP sont-ils configurés selon un guide de durcissement (type CIS) ?	M	« Puis-je voir un rapport de conformité aux benchmarks ? »
E4b	Une politique de durcissement des équipements est-elle formalisée ?	F	« Puis-je voir le guide de durcissement validé ? »
COMPLÉMENT DOMAINE B — Journalisation des consultations (assertion G3, référentiel étendu)	COMPLÉMENT DOMAINE B — Journalisation des consultations (assertion G3, référentiel étendu)	COMPLÉMENT DOMAINE B — Journalisation des consultations (assertion G3, référentiel étendu)	COMPLÉMENT DOMAINE B — Journalisation des consultations (assertion G3, référentiel étendu)
G3a	L'application journalise-t-elle techniquement toute consultation de document comptable sensible (horodatage + identifiant) ?	H	« Montrez-moi un extrait du journal des consultations. »
G3b	Une procédure exige-t-elle formellement la journalisation des consultations de documents sensibles ?	M	« Puis-je voir la procédure signée ? »
COMPLÉMENT DOMAINE C — Contrôle de version des documents (assertion G1, référentiel étendu)	COMPLÉMENT DOMAINE C, Contrôle de version des documents (assertion G1, référentiel étendu)	COMPLÉMENT DOMAINE, Contrôle de version des documents (assertion G1, référentiel étendu)	COMPLÉMENT DOMAINE, Contrôle de version des documents (assertion G1, référentiel étendu)
G1a	Un système de versionnement automatique est-il actif pour chaque document comptable généré par GIDOCEP ?	H	« Montrez-moi la configuration et l'historique des versions d'un document. »
G1b	Une procédure de gestion des versions documentaires est-elle formalisée ?	M	« Puis-je voir la procédure signée ? »

COMPLÉMENT DOMAINE C — Classification des documents (assertion G2, référentiel étendu)	COMPLÉMENT DOMAINE C — Classification des documents (assertion G2, référentiel étendu)	COMPLÉMENT DOMAINE Classification des documents (assertion G2, référentiel étendu)	COMPLÉMENT DOMAINE Classification des documents (assertion G2, référentiel étendu)
G2a	L'application permet-elle de classer techniquement les documents comptables (confidentiel, public, interne) ?	H	« Montrez-moi les niveaux de classification disponibles à l'écran. »
G2b	Une politique de classification des documents est-elle formalisée et diffusée aux utilisateurs ?	H	« Puis-je voir la politique signée ? »
COMPLÉMENT DOMAINE C — Droits d'accès par document (assertion G4, référentiel étendu)	COMPLÉMENT DOMAINE C — Droits d'accès par document (assertion G4, référentiel étendu)	COMPLÉMENT DOMAINE C — Droits d'accès par document (assertion G4, référentiel étendu)	COMPLÉMENT DOMAINE C — Droits d'accès par document (assertion G4, référentiel étendu)
G4a	Les droits d'accès sont-ils définis techniquement document par document ou dossier par dossier ?	H	« Montrez-moi le paramétrage des droits sur un document précis. »
G4b	Une matrice des droits d'accès par type de document est-elle formalisée ?	H	« Puis-je voir la matrice signée ? »
COMPLÉMENT DOMAINE D, Archivage légal (assertion G5, référentiel étendu)	COMPLÉMENT DOMAINE D — Archivage légal (assertion G5, référentiel étendu)	COMPLÉMENT DOMAINE Archivage légal (assertion G5, référentiel étendu)	COMPLÉMENT DOMAINE E Archivage légal (assertion G5, référentiel étendu)
G5a	Un système d'archivage électronique sécurisé (horodaté, intègre) est-il en place pour les documents à valeur légale ?	H	« Montrez-moi la configuration du système d'archivage. »
G5b	Une politique d'archivage définissant durées et modalités est-elle formalisée ?	M	« Puis-je voir la politique signée ? »
COMPLÉMENT DOMAINE E Destruction sécurisée (assertion G6, référentiel étendu)	COMPLÉMENT DOMAINE E — Destruction sécurisée (assertion G6, référentiel étendu)	COMPLÉMENT DOMAINE E Destruction sécurisée (assertion G6, référentiel étendu)	COMPLÉMENT DOMAINE Destruction sécurisée (assertion G6, référentiel étendu)
G6a	Un processus technique de destruction sécurisée (effacement certifié) des documents est-il disponible ?	M	« Montrez-moi le journal des destructions et les certificats d'effacement. »
G6b	Une procédure de destruction des documents est-elle formalisée et appliquée ?	M	« Puis-je voir la procédure signée ? »